LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Hedefli saldırgan → KANTEC uzak servis erişimi (sürekli açık, ortak hesap, MFA yok) → IPC → hat PLC'si → Safety PLC'de SF3 ışık perdesi muting süresini uzatır → operatör sıkışmayı açarken robot durmaz: ezilme	2	3	3	18	Kritik
İçeriden yetkisiz kişi (daha çok üretim isteyen operatör) → paylaşılan HMI parolası (fabrika ağı) → bakım modunda kapı kilidini köprüler → kapı açıkken konveyör/robot çalışır → el konveyör sıkışma noktasında kalır	2	3	2	12	Yüksek
Tedarik zinciri → sahte "Gradius v2.3" güncellemesi USB ile servis laptop'undan (C8) → robot kontrolcüsünün güvenli zone ayarı değişir → robot izinli alandan çıkar, bakım yapan teknisyene çarpar	1	3	1	3	Düşük → S=3, öne alınır

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1: kapı sadece ortak servis hesabıyla korunuyor (L=2), robotta ezilme ciddi yaralanma (S=3) ve uzak servis yolu internete sürekli açık (E=3). Puan gerekçeleri: S2 → paylaşılan HMI parolası zayıf (L=2), el sıkışması ciddi (S=3), HMI fabrika ağından erişilir (E=2). S3 → önce tedarikçi güncelleme kanalı ele geçirilmeli (L=1), çarpma ciddi (S=3), USB ile makinede yapılır (E=1).

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 3 (skor 3). Risk register'da "S=3" bayrağıyla işaretlenir ve skoru ne olursa olsun listenin üstünde kalır. Önlemler: sadece imzalı firmware, SBOM kontrolü, değişiklik kaydı; her güncellemeden sonra robot safety konfigürasyonunun CRC'si karşılaştırılır ve SF4 yeniden test edilir. Altın kural kontrolü: üç zincir de "veri çalındı" ile değil, insanın yaralanmasıyla bitiyor.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.